

Droit du numérique, automate Picard

Haider-Rayan Boudjemeline, B3 IIM, rattrapage

Ce que fait la borne

Picard veut poser des automates réfrigérés dans des campus. On choisit un produit sur l'écran, on paie par carte et le casier s'ouvre. La borne propose aussi de créer un compte fidélité Picard, donc elle récupère au minimum un mail ou un numéro de téléphone, l'historique des achats faits sur la machine, et elle passe par un terminal de paiement CB.

Le compte fidélité et le RGPD

Le compte fidélité est la première chose qui saute aux yeux sur cet automate, Lorsque Picard demande un mail ou un numéro pour créer le compte, ça confirme bien qu'on est dans le RGPD. Donc nous sommes bien dans la légalité pour les données collectées (le contrat pour le compte, le consentement si on veut envoyer des promos), une durée de conservation fixée à l'avance, notifiée et respectée, et un moyen simple pour l'utilisateur de supprimer son compte. Sur une borne dans un couloir de fac, je vois mal quelqu'un lire une politique de confidentialité de 6 pages sur un écran tactile, donc il faut une version courte affichée avant la création du compte et un QR code vers la version complète. La CNIL a déjà par exemple Carrefour, qui a pris 2,25 millions en 2020 en partie sur les durées de conservation.

Le compte doit collecter le minimum, un mail ou un numéro suffit, pas besoin de l'adresse postale pour acheter des lasagne. L'écran doit afficher les infos de l'article 13 du RGPD avant la création du compte, en gros qui est responsable du traitement et pourquoi on collecte, combien de temps on garde et comment on fait pour accéder à ses données ou supprimer son compte. Sur picard.fr la politique de confidentialité annonce 25 mois de conservation après le dernier contact pour le programme fidélité, la borne doit reprendre la même règle, et avoir sa ligne dans le registre des traitements (article 30) puisque c'est un nouveau point de collecte.

Le compte a aussi besoin de CGU, acceptées à l'écran avec une vraie case à cocher, et Picard doit garder la preuve du clic (date et heure, version des CGU acceptée) pour pouvoir prouver le contrat si un étudiant conteste plus tard. Autre chose, le mail doit être confirmé par un lien envoyé dans la boîte avant que le compte soit actif, le double opt-in. Sans ça n'importe qui peut créer un compte avec l'adresse d'un autre étudiant, lui faire recevoir des promos ou brouiller son historique. En gros c'est une usurpation d'identité, et côté pénal ça vaut jusqu'à un an de prison et 15 000 euros d'amende (article 226-4-1 du code pénal), donc Picard a intérêt à fermer la porte dès l'inscription.

Il y a aussi des sous-traitants (l'exploitant de l'automate, la société de paiement, l'hébergeur des comptes, l'outil qui envoie les mails). Chacun doit signer un contrat article 28 qui fixe les instructions écrites et le niveau de sécurité attendu, et qui dit ce qu'on fait des données en fin de contrat. Picard a déjà un DPO, l'adresse est sur leur site, donc c'est lui qui valide tout ça. Le truc en plus par rapport à un site web, c'est que la machine est physique et dans un lieu public. Pas de comptes en clair sur le disque de la borne. La session doit se fermer toute seule si l'étudiant part sans se déconnecter. Et quelqu'un qui force la porte ne doit pas repartir avec une base de données, donc du chiffrement et des mises à jour poussées à distance. Si Picard

compte utiliser l'historique d'achat pour du marketing ciblé, on est sur du profilage, et la CNIL demande une analyse d'impact (AIPD) dès qu'on cumule profilage et personnes vulnérables, les mineurs par exemple.

Les promos et les mineurs

Pour la prospection par mail, la règle CNIL est l'opt-in, une case non cochée par défaut et un lien de désinscription dans chaque mail. L'exception pour les clients existants existe, mais créer un compte sans acheter ne fait pas un client selon la CNIL, donc je partirais sur la case à cocher dans tous les cas. Autre point que j'avais pas vu au début, sur un campus il y a des étudiants de 17 ans. En France le consentement d'un mineur pour un service en ligne n'est valable seul qu'à partir de 15 ans (article 45 de la loi Informatique et Libertés), en dessous il faut l'accord d'un parent. À 17 ans ça passe pour le compte, mais il faut quand même une case "j'ai plus de 15 ans" et éviter le profilage marketing sur ce public, sinon on retombe sur l'AIPD dont je parlais plus haut.

Vendre dans un couloir

Je pensais tomber dans la vente à distance, mais l'article L221-2 du code de la consommation exclut justement les contrats conclus par distributeurs automatiques du chapitre sur la vente à distance. Du coup pas de droit de rétractation de 14 jours, et de toute façon l'article L221-28 (4°) l'écarte pour les biens qui se périment vite. Le reste du code de la consommation s'applique. Les prix doivent être affichés en euros TTC avant l'achat (arrêté du 3 décembre 1987 sur l'information du consommateur sur les prix), avec le prix au kilo pour les produits préemballés. L'amende administrative pour un prix pas affiché monte à 15 000 euros pour une société, et la DDPP du Rhône a mis 20 000 euros à un Carrefour Market de Villeurbanne pour ça (source : page injonctions et sanctions de la DGCCRF). Les CGV doivent être consultable sur la borne, pas juste un lien vers le site.

Pour les infos alimentaires, le règlement INCO 1169/2011 demande en vente à distance que les mentions obligatoires (ingrédients avec les allergènes, valeurs nutritionnelles) soient disponibles avant l'achat, mais son article 14 paragraphe 3 exempte aussi les distributeurs automatiques de cette règle, ce qui colle avec l'exclusion du code de la conso vue plus haut. Donc la borne n'est pas obligée de montrer la liste des ingrédients avant qu'on paie, l'emballage suffit. Perso je les mettrais à l'écran quand même, au moins les allergènes, parce qu'un étudiant allergique ne peut pas lire le sachet avant de l'avoir acheté. Le surgelé doit rester à -18 °C, c'est le dépliant chaîne du froid de la DGCCRF qui le dit. Donc la borne à besoin d'une sonde. Et d'une coupure des ventes si la température remonte, sinon on vend un produit dangereux. Il faut aussi un vrai service client. Un produit bloqué dans le casier ou un paiement débité deux fois, ça arrive sur toutes les machines. Il faut un numéro ou un QR code sur la borne et un reçu envoyé par mail, et surtout une règle claire sur qui rembourse (Picard, pas le prestataire de la machine). Perso j'ai déjà perdu 2 euros dans un distributeur de la fac sans aucun numéro à appeler, donc pour la borne Picard il faut au moins une adresse de réclamation visible sur la façade.

Ce qui est affiché à l'écran

Si l'interface de la borne est un service en ligne (catalogue chargé depuis un serveur, appli mobile en face), la LCEN demande les mentions légales habituelles, raison sociale, capital et RCS, adresse et mail de contact, plus le nom de l'hébergeur. L'amende pour une société qui les oublie monte jusqu'à 375 000 euros (source : economie.gouv, page sur les mentions d'un site internet). Pour les cookies, je pense pas qu'une borne en pose au sens classique, il n'y a pas de navigateur perso, mais si l'appli mobile liée au compte en utilise il faut le bandeau de consentement comme partout. Côté propriété intellectuelle, la marque Picard et son logo sont déposés à l'INPI, la protection dure 10 ans renouvelable est ne vaut que dans les classes déclarées. Les photos des produits à l'écran doivent appartenir à Picard ou être sous licence.

Le paiement

Le terminal doit être un modèle certifié et la société de paiement conforme PCI DSS. Picard ne doit jamais stocker de numéro de carte, ni sur la borne ni dans le compte fidélité. Si le compte permet d'enregistrer une carte pour payer plus vite depuis l'appli, on tombe sous la DSP2 et l'authentification forte (deux facteurs), avec des exemptions pour les petits montants. Sur la borne elle-même, Le sans contact classique suffit, et l'ACPR est l'autorité qui surveille les prestataires de paiement, pas Picard directement.

Ce qui peut mal tourner

Ce qui me fait le plus peur, c'est une fuite des données du compte fidélité. Mails, téléphones, historique d'achats et heures de passage de milliers d'étudiant, avec une notification à la CNIL sous 72 heures. Après il y a le côté physique. Une borne dans un couloir se fait vandaliser, et un TPE accessible à tout le monde peut recevoir un skimmer, le faux lecteur qui copie les cartes. Le sanitaire aussi. Une panne de froid une nuit, et le lendemain on vend des produits décongelés puis recongelés, avec un rappel produit derrière. L'alcool n'est pas au catalogue Picard, donc pas de souci de vente aux mineurs pour du surgelé, ce serait différent avec d'autres produits. Il reste les incidents de paiement (double débit, casier bloqué) et le litige avec l'école, qui paie si la borne provoque un dégât des eaux ? Le contrat de concession de l'université Lyon 2 pour ses distributeurs met tout sur le dos de l'exploitant, la maintenance comme les assurances, avec une redevance d'au moins 15 % du chiffre d'affaires. Picard doit s'attendre au même genre de convention.

Qui contrôle

Pour les données, c'est la CNIL. En 2025 elle a rendu 83 sanctions pour 486,8 millions d'euros, dont dix sur la prospection commerciale (source : bilan sanctions 2025 sur cnil.fr). Le cas qui ressemble le plus au sujet est la sanction de 3,5 millions du 30 décembre 2025 contre une enseigne (pas nommée) qui envoyait les mails et téléphones de son programme fidélité à un réseau social pour de la pub ciblée, sans que le formulaire d'adhésion en parle. Pour les prix et les CGV, et pour la sécurité des aliments, c'est la DGCCRF et ses services départementaux (DDPP), qui peuvent mettre des amendes administratives ou des injonctions, comme en avril 2026 contre quatre enseignes sur l'origine et les prix des fruits et légumes. L'ANSSI ne contrôle pas Picard, elle publie des recommandations utiles pour sécuriser la borne. L'INPI

gère la marque, et l'ACPR les prestataires de paiement. Bref, la même borne peut recevoir une visite de la DDPP pour les prix et le froid et un contrôle CNIL pour le compte, avec des amendes qui n'ont rien à voir en montant, 15 000 euros d'un côté et plusieurs millions de l'autre comme pour Carrefour.